File Inclusion Secure Coding

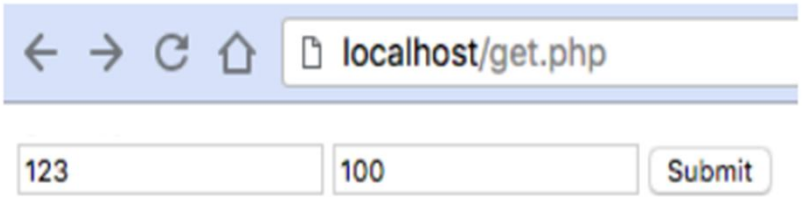
$_GET

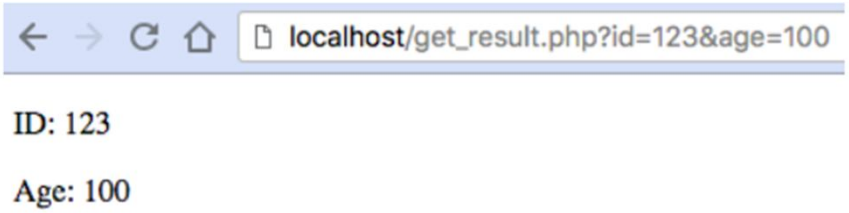
```
<form action="get.php" method="get">
  이름 : <input type="text" name="id">
  나이 : <input type="text" name="age">
        < input type="submit">
</form>
```

<< get.php >>

```
<?php
   echo  $_GET [ "id" ];
   echo  $_GET [ "age" ];
?>
```

- submit 버튼을 누르면 '이름'과 '나이'의 값을 **get.php** 페이지로 전송





$_POST

```
<! DOCTYPE html>
<html lang = "kr" >
<body>
<form action = "call.php“ method = "POST" >
   글자 : <input type = "text" name = "testText" />
  숫자 : <input type = "number" name = "testNumber" />
   <input type = "submit" value = "전송" />
</form>
</body>
</html>
```

```
<?php
   $v_Text = $_POST [ "testText" ];
   $v_Number = $_POST [ "testNumber" ];
   echo " { $v_Text } 와 { $v_Number } 을 화면에 출력했습니다." ;
?>
```

<<call.php>>

$_POST
- POST 방식으로 데이터를 넘기고 받을 때 사용
- 데이터를 보내는 php에서는 form에서 method를 POST 던지게 됨
- 데이터를 받는 php에서는 $_POST를 이용해 던져진 데이터를 받음

- submit(전송) 버튼을 누르면 글자와 숫자가 call.php에 전달

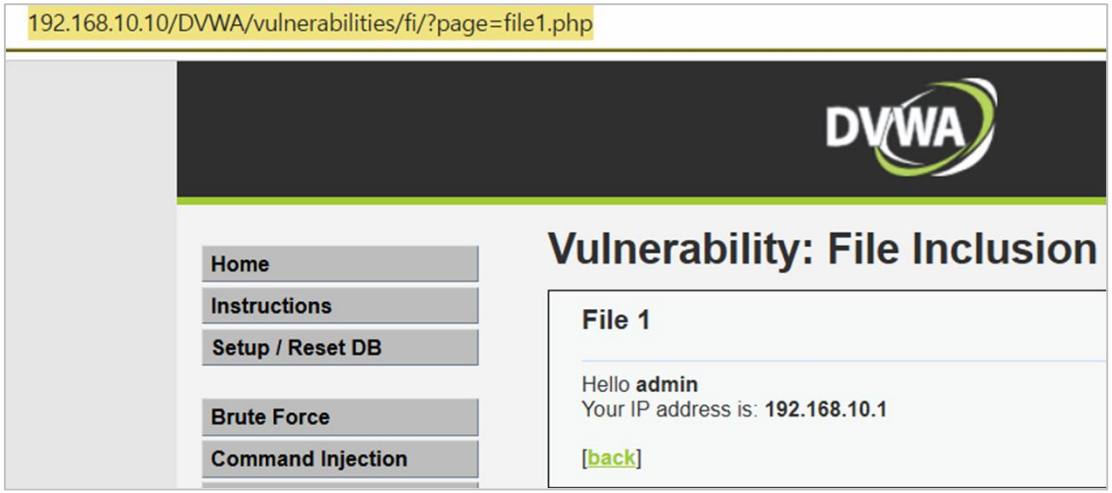
테스트 와 123을 화면에 출력했습니다.

Low File Inclusion Source

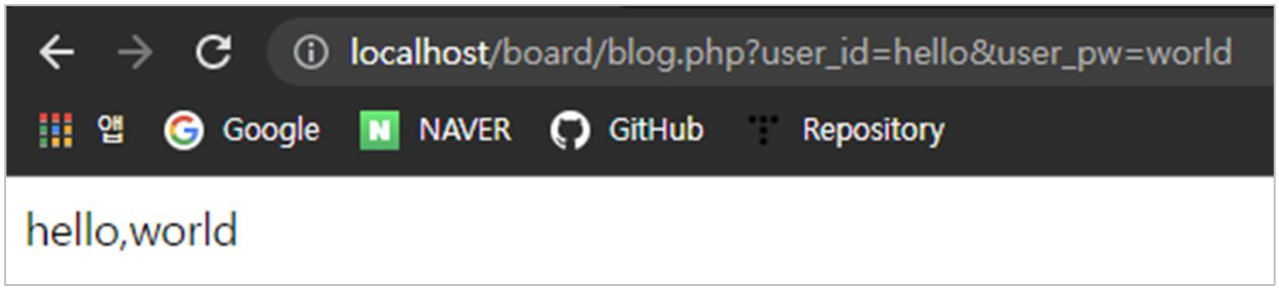
```php
<?php

// The page we wish to display
$file = $_GET[ 'page' ];

?>
```

- GET은 URL에 데이터가 표시
- $_GET['x'] : URL에 X 변수에 명시된 값을 의미

File1.php 파일 실행



```php
<?php
  echo $_GET['user_id'].','.$_GET['user_pw'];
?>
```



Medium File Inclusion Source

```php
<?php

// The page we wish to display
$file = $_GET[ 'page' ];

// Input validation
$file = str_replace( array( "http://", "https://" ), "", $file );
$file = str_replace( array( "../", "..\\" ), "", $file );

?>
```

- Page에 들어 있는 값이 http://(또는 https://)나 ../ (또는 ..₩₩)이 포함되어 있는 경우 해당 값들은 모두 공백으로 처리
- Page에 http가 들어 있는 것은 타사이트의 파일을 호출해서 실행되는 것을 막기 위함

• array( )

-하나의 변수에 여러 값을 저장할 수 있는 특수한 변수를 말함

```php
<?php
  $var1 = "one";
  $var2 = "two";
  $var3 = "tree";
?>
```

```php
<?php
  $varArr = array("one", "two", "tree");
  $varArr2 = ["one", "two", "tree"];      / php5.4 이상 [ ]로 배열 선언
?>
```

• str_replace() 함수

- 문자열에서 특정 문자열을 검색해서 다른 문자열로 바꾸는 함수

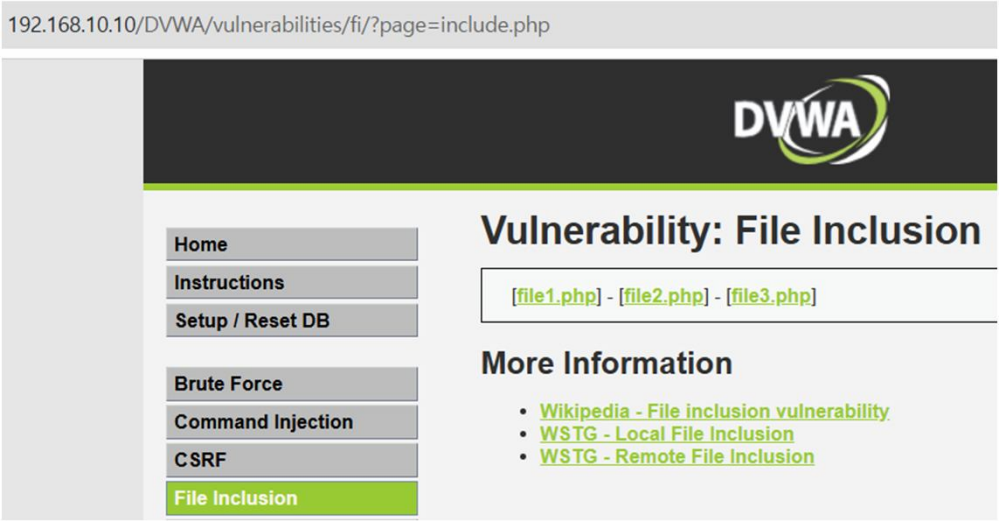
```php
$str = 'Hello, world!';
$new_str = str_replace('world!', 'universe!', $str);
echo $new_str;
```

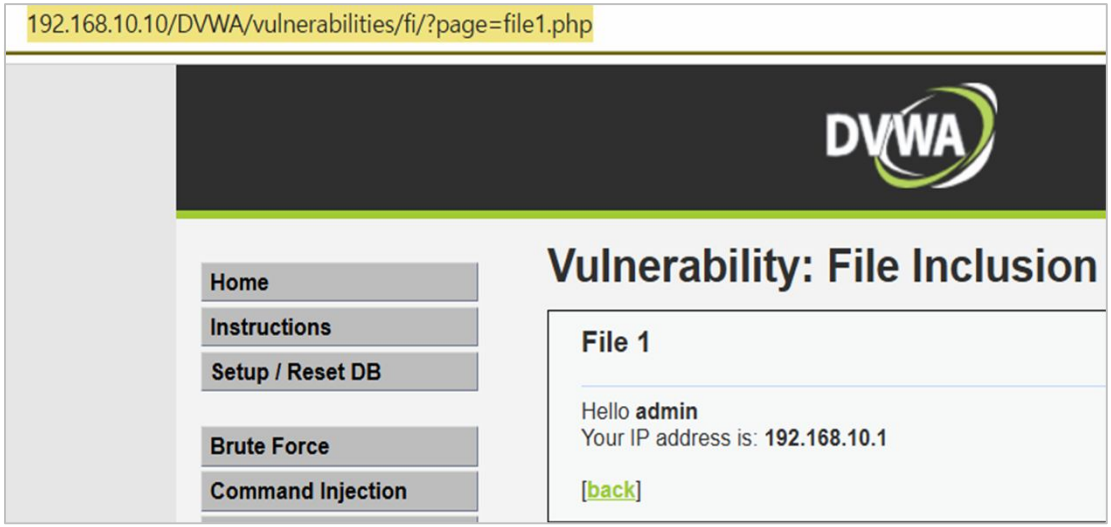
Hello, universe!

High File Inclusion Source

```php
<?php

// The page we wish to display
$file = $_GET[ 'page' ];

// Input validation
if( !fnmatch( "file*", $file ) && $file != "include.php" ) {
    // This isn't the page we want!
    echo "ERROR: File not found!";
    exit;
}

?>
```

첫 페이지도 아니고 page의 파일명이 file*형식이 아닌 경우 오류로 처리한다.





!fnmatch("file*", $file) && $file !="include.php")

첫 페이지도 아니고 page의 파일명이 file*형식이 아닌 경우 오류로 처리한다.

fnmatch 함수

- Shell 패턴을 사용하여 문자열이 패턴과 일치하는지 여부를 확인하는데 사용
- Shell 패턴은 와일드카드(*)와 물음표(?)를 사용하여 문자열을 일치시킬 패턴을 지정

```
fnmatch ( string $pattern , string $filename , int $flags = 0 ) : bool
$pattern = 'file*.txt';
$filename = 'file123.txt';

if (fnmatch($pattern, $filename)) {
    echo "Filename matches the pattern.";
} else {
    echo "Filename does not match the pattern.";
}
```

File Upload Secure Coding

Low File Upload Source

```php
<?php

if( isset( $_POST[ 'Upload' ] ) ) {
    // Where are we going to be writing to?
    $target_path  = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";
    $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );

    // Can we move the file to the upload folder?
    if( !move_uploaded_file( $_FILES[ 'uploaded' ][ 'tmp_name' ], $target_path ) ) {
        // No
        echo '<pre>Your image was not uploaded.</pre>';
    }
    else {
        // Yes!
        echo "<pre>{$target_path} succesfully uploaded!</pre>";
    }
}

?>
```

192.168.10.10/DVWA/vulnerabilities/upload/#

DVWA

- Home
- Instructions
- Setup / Reset DB

- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload

Vulnerability: File Upload

Choose an image to upload:

파일 선택 선택된 파일 없음

Upload

../../hackable/uploads/test.txt succesfully uploaded!

More Information

```html
<! DOCTYPE html>
<html lang = "kr" >
<body>
<!-- form에서 method를 POST로 해서 전송-->
<form method = "POST" action = "call.php" >
   글자 : <input type = "text" name = "testText" />
  숫자 : <input type = "number" name = "testNumber" />
   <input type = "submit" value = "전송" />
</form>
</body>
</html>
```

```php
<?php
   $v_Text = $_POST [ "testText" ];
   $v_Number = $_POST [ "testNumber" ];
   echo " { $v_Text } 와 { $v_Number } 을 화면에 출력했습니다." ;
?>
```

<<call.php>>

$_POST
- POST 방식으로 데이터를 넘기고 받을 때 사용
- 데이터를 보내는 php에서는 form에서 method를 POST 던지게 됨
- 데이터를 받는 php에서는 $_POST를 이용해 던져진 데이터를 받음

testText testNumber

글자 : 테스트 숫자 : 123 전송

테스트 와 123을 화면에 출력했습니다.

basename(경로 , 접미사)

- 주어진 경로에서 파일 이름만 반환
- 접미사가 입력되면 파일 이름에서 해당하는 접미사는 제거됨

```
<?php
    $test_path = "/home/work/menu/test.php";
    echo basename ($test_path);
    echo "<br>";
    echo basename($test_path,".php");
?>
```

```
test.php
test
```

```
<?php
 echo "basename("/etc/sudoers.d", ".d");
 echo "basename("/etc/sudoers.d");
 echo "basename("/etc/passwd");
?>
```

```
sudoers
sudoers.d
passwd
```

$_FILES['userfile']['name’]

- 클라이언트 머신에 존재하는 파일의 원래 이름

$_FILES['userfile']['type ']

- 브라우저가 이 정보를 제공할 경우에, 파일의 mime 형식. 예를 들면 "image/gif".

$_FILES['userfile']['size ']

- 업로드된 파일의 바이트로 표현한 크기.

$_FILES['userfile']['tmp_name ']

- 서버에 저장된 업로드된 파일의 임시 파일 이름

- 웹 서버에 임시로 저장된 파일의 위치와 이름

- 'tmp_name'는 임시파일명을 지정 해주는 것으로 ' tmp_name ' 를 써야 함

bool **move_uploaded_file** (string *$filename* , string *$destination*)

* move_uploaded_file()

- 서버로 전송된 파일을 저장할 때 사용하는 함수

- 업로드된 파일을 지정한 위치에 지정된 파일이름으로 이동

Medium
File Upload Source

```php
<?php

if( isset( $_POST[ 'Upload' ] ) ) {
    // Where are we going to be writing to?
    $target_path  = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";
    $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );

    // File information
    $uploaded_name = $_FILES[ 'uploaded' ][ 'name' ];
    $uploaded_type = $_FILES[ 'uploaded' ][ 'type' ];
    $uploaded_size = $_FILES[ 'uploaded' ][ 'size' ];

    // Is it an image?
    if( ( $uploaded_type == "image/jpeg" || $uploaded_type == "image/png" ) &&
        ( $uploaded_size < 100000 ) ) {

        // Can we move the file to the upload folder?
        if( !move_uploaded_file( $_FILES[ 'uploaded' ][ 'tmp_name' ], $target_path ) ) {
            // No
            echo '<pre>Your image was not uploaded.</pre>';
        }
        else {
            // Yes!
            echo "<pre>{$target_path} succesfully uploaded!</pre>";
        }
    }
    else {
        // Invalid file
        echo '<pre>Your image was not uploaded. We can only accept JPEG or PNG images.</pre>';
    }
}

?>
```

High File Upload Source

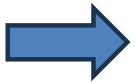
```php
<?php

if( isset( $_POST[ 'Upload' ] ) ) {
    // Where are we going to be writing to?
    $target_path  = DVWA_WEB_PAGE_TO_ROOT . "hackable/uploads/";
    $target_path .= basename( $_FILES[ 'uploaded' ][ 'name' ] );

    // File information
    $uploaded_name = $_FILES[ 'uploaded' ][ 'name' ];
    $uploaded_ext  = substr( $uploaded_name, strrpos( $uploaded_name, '.' ) + 1);
    $uploaded_size = $_FILES[ 'uploaded' ][ 'size' ];
    $uploaded_tmp  = $_FILES[ 'uploaded' ][ 'tmp_name' ];

    // Is it an image?
    if( ( strtolower( $uploaded_ext ) == "jpg" || strtolower( $uploaded_ext ) == "jpeg" || strtolower( $uploaded_ext ) == "png" ) &&
        ( $uploaded_size < 100000 ) &&
        getimagesize( $uploaded_tmp ) ) {

        // Can we move the file to the upload folder?
        if( !move_uploaded_file( $uploaded_tmp, $target_path ) ) {
            // No
            echo '<pre>Your image was not uploaded.</pre>';
        }
        else {
            // Yes!
            echo "<pre>{$target_path} succesfully uploaded!</pre>";
        }
    }
    else {
        // Invalid file
        echo '<pre>Your image was not uploaded. We can only accept JPEG or PNG images.</pre>';
    }
}

?>
```

substr( )

- 문자열에서 주어진 특정 위치부터 특정 길이만큼의 문자열을 잘라서 추출

- substr([문자열], [시작위치], [길이]);

```
$str = "PHP substr";
$str = substr($str, 4, 3);
echo '$str : '.$str;
```



```
$str : sub
```

strpos( )

- strpos(문자열, '찾을문자열' , 시작위치);

- 대상 문자열을 뒤에서 부터 검색하여 찾고자 하는 문자열이 몇 번째 위치에 있는지를 리턴하는 함수

```
$str = 'strrpos';
echo strrpos($str, "r");
```

```
3
```